Server Administration and Configuration: Windows 2008-based systems

INSTRUCTIONS:
Please respond to each question by placing an "X" in the "Yes", "No" or "N/A" column or by providing the information requested. Use the "Tab" key to move between items. Use the "Additional information" field for explanatory comments, if necessary. If an item does not have an "Additional information" field, and you need to explain your answer, use the space at the end of the questionnaire and reference the item being explained, e.g. RE: Item 1.2-This is the explanation.

Source: This document is based on security requirements for Windows 2008 from the System Network Attack Center (SNAC).

Questionnaire completed by: _____

Contact number for follow-up questions: _____

Date Completed: _____

1. General

Number	Question	Yes	No	N/A
1.1	**General**			
1.1.1	Have any servers currently running Windows 2012 been upgraded directly from Windows 2008? *If you answered "Yes" to this question, please use the Additional information box below to identify the upgraded servers or provide a list of these servers in electronic format to the auditors when you return this questionnaire.* Additional information: _____	☐	☐	☐

2. Service Packs and Hotfixes

Number	Question	Yes	No	N/A
2.1	Has the latest service pack been applied to all Windows 2008 servers? *This will be verified when internal vulnerability scans are conducted.* Additional information: _____	☐	☐	☐

Number	Question	Yes	No	N/A
2.2	Have all vendor recommended Hotfix roll-ups been applied to all Windows 2008 servers? *This will be verified when internal vulnerability scans are conducted.* Additional information:	☐	☐	☐

3. Account Policy Settings

Number	Question	Yes / No / N/A Or Setting
3.1	**Password Policy**	
3.1.1	What setting has been applied to "Enforce Password History": *If there is a mission critical reason why this setting has not been configured, use the Additional information box below to explain the mission critical reason.* Additional information:	
3.1.2	What setting has been applied to "Maximum Password Age": *If there is a mission critical reason why this setting has not been configured, use the Additional information box below to explain the mission critical reason.* Additional information:	
3.1.3	What setting has been applied to "Minimum Password Age": *If there is a mission critical reason why this setting has not been configured, use the Additional information box below to explain the mission critical reason.* Additional information:	
3.1.4	What setting has been applied to "Minimum Password Length": *If there is a mission critical reason why this setting has not been configured, use the Additional information box below to explain the mission critical reason.* Additional information:	
3.1.5	What setting has been applied to "Passwords must meet complexity requirements?": *If there is a mission critical reason why this setting has not been configured, use the Additional information box below to explain the mission critical reason.* Additional information:	

Number	Question	Yes	No	N/A
		Or Setting		
3.1.6	What setting has been applied to "Store password using reversible encryption for all users in the domain": *If there is a mission critical reason why this setting has not been configured, use the Additional information box below to explain the mission critical reason.* Additional information: _____			
3.2	**Account Lockout Policy**			
3.2.1	What setting has been applied to "Account lockout duration": *If there is a mission critical reason why this setting has not been configured, use the Additional information box below to explain the mission critical reason.* Additional information: _____			
3.2.2	What setting has been applied to "Account lockout threshold": *If there is a mission critical reason why this setting has not been configured, use the Additional information box below to explain the mission critical reason.* Additional information: _____			
3.2.3	What setting has been applied to "Reset account lockout counter after": *If there is a mission critical reason why this setting has not been configured, use the Additional information box below to explain the mission critical reason.* Additional information: _____			
3.3	**Auditing Policy**			
3.3.1	Is an audit policy configured on all Windows 2008 servers? *If <u>all</u> of your Windows 2008 servers have an auditing policy configured, answer this question "Yes." If only SOME of your Windows 2008 servers have an auditing policy configured, answer this question "Yes" and list those servers that do not have an auditing policy configured in the Additional information box below. If <u>none</u> of your Windows 2008 servers have an auditing policy configured, answer this question "No" and skip to Section 3.6, User Rights Assignment. Do not complete the rest of this section.* Additional information: _____	☐	☐	☐

<table>
<tr><th>Number</th><th>Question</th><th>Yes / No / N/A
Or
Setting</th></tr>
<tr><td>3.3.2</td><td>What audit policy parameters have been configured for all Windows 2008 servers in the following areas?
<table>
<tr><th>Item</th><th>Success</th><th>Failure</th></tr>
<tr><td>Audit Account Logon Events</td><td>☐</td><td>☐</td></tr>
<tr><td>Audit Account Management</td><td>☐</td><td>☐</td></tr>
<tr><td>Audit Directory Service Access</td><td>☐</td><td>☐</td></tr>
<tr><td>Audit Logon Events</td><td>☐</td><td>☐</td></tr>
<tr><td>Audit Object Access</td><td>☐</td><td>☐</td></tr>
<tr><td>Audit Policy Change</td><td>☐</td><td>☐</td></tr>
<tr><td>Audit Privilege Use</td><td>☐</td><td>☐</td></tr>
<tr><td>Audit Process Tracking</td><td>☐</td><td>☐</td></tr>
<tr><td>Audit System Events</td><td>☐</td><td>☐</td></tr>
</table>
Additional information: _____</td><td></td></tr>
<tr><td>3.4</td><td>User Rights Assignment</td><td></td></tr>
<tr><td>3.4.1</td><td>Which users and groups have been assigned “Access this computer from the network”:
Additional information: _____</td><td></td></tr>
<tr><td>3.4.2</td><td>Which users and groups have been assigned “Act as part of the operating system”:
Additional information: _____</td><td></td></tr>
<tr><td>3.4.3</td><td>Which users and groups have been assigned “Add workstations to the domain”:
Additional information: _____</td><td></td></tr>
<tr><td>3.4.4</td><td>Which users and groups have been given the right to “Back up files and directories”:
Additional information: _____</td><td></td></tr>
<tr><td>3.4.5</td><td>Which users and groups have been assigned “Bypass traverse checking”:
Additional information: _____</td><td></td></tr>
<tr><td>3.4.6</td><td>Which users and groups have been assigned “Change the system time”:
Additional information: _____</td><td></td></tr>
</table>

Number	Question	Yes / No / N/A Or Setting
3.4.7	Which users and groups have been assigned "Create a pagefile": Additional information:	
3.4.8	Which users and groups have been assigned "Create a token object": Additional information:	
3.4.9	Which users and groups have been assigned "Create permanent shared objects": Additional information:	
3.4.10	Which users and groups have been assigned "Debug programs": Additional information:	
3.4.11	Which users and groups have been assigned "Deny access to this computer from the network": Additional information:	
3.4.12	Which users and groups have been assigned "Deny logon as a batch job": Additional information:	
3.4.13	Which users and groups have been assigned "Deny logon as a service": Additional information:	
3.4.14	Which users and groups have been assigned "Deny logon locally": Additional information:	
3.4.15	Which users and groups have been assigned "Enable computer and user accounts to be trusted for delegation": Additional information:	
3.4.16	Which users and groups have been assigned "Force shutdown from a remote system": Additional information:	
3.4.17	Which users and groups have been assigned "Generate security audits": Additional information:	
3.4.18	Which users and groups have been assigned "Increase quotas": Additional information:	
3.4.19	Which users and groups have been assigned "Increase scheduling priority": Additional information:	

Number	Question	Yes / No / N/A Or Setting
3.4.20	Which users and groups have been assigned "Load and unload device drivers": Additional information:	
3.4.21	Which users and groups have been assigned "Lock pages in memory": Additional information:	
3.4.22	Which users and groups have been assigned "Log on as a batch job": Additional information:	
3.4.23	Which users and groups have been assigned "Log on as a service": Additional information:	
3.4.24	Which users and groups have been assigned "Log on locally": Additional information:	
3.4.25	Which users and groups have been assigned "Manage auditing and security log": Additional information:	
3.4.26	Which users and groups have been assigned "Modify firmware environment variables": Additional information:	
3.4.27	Which users and groups have been assigned "Profile single process": Additional information:	
3.4.28	Which users and groups have been assigned "Profile system performance": Additional information:	
3.4.29	Which users and groups have been assigned "Remove computer from docking station": Additional information:	
3.4.30	Which users and groups have been assigned "Replace a process-level token": Additional information:	
3.4.31	Which users and groups have been assigned "Restore files and directories": Additional information:	
3.4.32	Which users and groups have been assigned "Shut down the system": Additional information:	

Number	Question	Yes / No / N/A Or Setting
3.4.33	Which users and groups have been assigned "Synchronize directory service data": Additional information:	
3.4.34	Which users and groups have been assigned "Take ownership of files or other objects": Additional information:	
3.5	**Security Attributes**	
	For the security attributes listed below, enter the security setting(s) applied to your Windows 2008 servers.	
3.5.1	What security setting(s) has/have been assigned to "Access this computer from the network": Additional information:	
3.5.2	What security setting(s) has/have been assigned to "Additional restrictions for anonymous connections": Additional information:	
3.5.3	What security setting(s) has/have been assigned to "Allow Automatic Administrator Logon": Additional information:	
3.5.4	What security setting(s) has/have been assigned to "Allow Server Operators to schedule tasks (domain controllers only)": Additional information:	
3.5.5	What security setting(s) has/have been assigned to "Allow system to be shut down without having to log on": Additional information:	
3.5.6	What security setting(s) has/have been assigned to "Allowed to eject removable NTFS media": Additional information:	
3.5.7	What security setting(s) has/have been assigned to "Amount of idle time required before disconnecting session": Additional information:	
3.5.8	What security setting(s) has/have been assigned to "Audit the access of global system objects": Additional information:	
3.5.9	What security setting(s) has/have been assigned to "Audit use of Backup and Restore privilege": Additional information:	
3.5.10	What security setting(s) has/have been assigned to "Automatically log off users when logon time expires": Additional information:	

Number	Question	Yes / No / N/A Or Setting
3.5.11	What security setting(s) has/have been assigned to "Automatically log off users when logon time expires (local)": Additional information:	
3.5.12	What security setting(s) has/have been assigned to "Clear virtual memory pagefile when system shuts down": Additional information:	
3.5.13	What security setting(s) has/have been assigned to "Digitally sign client communication (always)": Additional information:	
3.5.14	What security setting(s) has/have been assigned to "Digitally sign client communication (when possible)": Additional information:	
3.5.15	What security setting(s) has/have been assigned to "Digitally sign server communication (always)": Additional information:	
3.5.16	What security setting(s) has/have been assigned to "Digitally sign server communication (when possible)": Additional information:	
3.5.17	What security setting(s) has/have been assigned to "Disable CTRL+ALT+DEL requirement for logon": Additional information:	
3.5.18	What security setting(s) has/have been assigned to "Disable Media Autoplay": Additional information:	
3.5.19	What security setting(s) has/have been assigned to "Do not display last user name in logon screen": Additional information:	
3.5.20	What security setting(s) has/have been assigned to "LAN Manager authentication level": Additional information:	
3.5.21	What security setting(s) has/have been assigned to "Message text for users attempting to log on": Additional information:	
3.5.22	What security setting(s) has/have been assigned to "Message title for users attempting to log on": Additional information:	
3.5.23	What security setting(s) has/have been assigned to "Number of previous logons to cache (in case domain controller is not available)": Additional information:	

Number	Question	Yes	No	N/A
		Or Setting		
3.5.24	What security setting(s) has/have been assigned to "prevent system maintenance of computer account password": Additional information:			
3.5.25	What security setting(s) has/have been assigned to "Prevent users from installing printer drivers": Additional information:			
3.5.26	What security setting(s) has/have been assigned to "Prompt user to change password before expiration": Additional information:			
3.5.27	What security setting(s) has/have been assigned to "Recovery Console: Allow automatic administrative logon": Additional information:			
3.5.28	What security setting(s) has/have been assigned to "Recovery Console: Allow floppy copy and access to all drives and folders": Additional information:			
3.5.29	What security setting(s) has/have been assigned to "Rename administrator account": Additional information:			
3.5.30	What security setting(s) has/have been assigned to "Rename guest Account": Additional information:			
3.5.31	What security setting(s) has/have been assigned to "Restrict CD-ROM access to locally logged on user only ": Additional information:			
3.5.32	What security setting(s) has/have been assigned to "Restrict floppy access to locally logged on user only": Additional information:			
3.5.33	What security setting(s) has/have been assigned to "Secure channel: digitally encrypt or sign secure channel data (always)": Additional information:			
3.5.34	What security setting(s) has/have been assigned to "Secure channel: Digitally encrypt secure channel data (when possible)": Additional information:			
3.5.35	What security setting(s) has/have been assigned to "Secure channel: Digitally sign secure channel data (when possible)": Additional information:			

Number	Question	Yes	No	N/A	Or Setting
3.5.36	What security setting(s) has/have been assigned to "Secure channel: Require strong (Windows 2008 or later) session key": Additional information:				
3.5.37	What security setting(s) has/have been assigned to "Secure system partition (for RISC platforms only)": Additional information:				
3.5.38	What security setting(s) has/have been assigned to "Send unencrypted password to connect to third-party SMB servers": Additional information:				
3.5.39	What security setting(s) has/have been assigned to "Shut down system immediately if unable to log security audits": Additional information:				
3.5.40	What security setting(s) has/have been assigned to "Smart card removal behavior": Additional information:				
3.5.41	What security setting(s) has/have been assigned to "Strengthen default permissions of global system objects (e.g., Symbolic Links) ": Additional information:				
3.5.42	What security setting(s) has/have been assigned to "Unsigned driver installation behavior": Additional information:				
3.5.43	What security setting(s) has/have been assigned to "Unsigned non-driver installation behavior": Additional information:				
3.6	**Event Log Settings**				
	For the event log settings listed below, enter the security setting(s) applied to your Windows 2008 servers.				
3.6.1	What security setting(s) has/have been assigned to "Maximum application log size": Additional information:				
3.6.2	What security setting(s) has/have been assigned to "Maximum security log size": Additional information:				
3.6.3	What security setting(s) has/have been assigned to "Maximum system log size": Additional information:				
3.6.4	What security setting(s) has/have been assigned to "Restrict guest access to application log": Additional information:				

Number	Question	Yes	No	N/A
		Or Setting		
3.6.5	What security setting(s) has/have been assigned to "Restrict guest access to security log": Additional information:			
3.6.6	What security setting(s) has/have been assigned to "Restrict guest access to system log": Additional information:			
3.6.7	What security setting(s) has/have been assigned to "Retain application log": Additional information:			
3.6.8	What security setting(s) has/have been assigned to "Retain security log": Additional information:			
3.6.9	What security setting(s) has/have been assigned to "Retain system log": Additional information:			
3.6.10	What security setting(s) has/have been assigned to "Retention method for application log": Additional information:			
3.6.11	What security setting(s) has/have been assigned to "Retention method for security log": Additional information:			
3.6.12	What security setting(s) has/have been assigned to "Retention method for system log": Additional information:			
3.6.13	What security setting(s) has/have been assigned to "Shut down the computer when the security audit log is full": Additional information:			
3.7	**System Services Settings**			
3.7.1	Have non-essential services been disabled on all Windows 2008 servers? **Please provide a "DumpSec" "Dump Services" report for all Windows 2008 servers**. If you do not have "DumpSec", it can be downloaded from www.somarsoft.com. *If you answered "No" to this question, and there a mission critical reason why normally disabled services are running, use the Additional information box below to explain the mission critical reason.* Additional information:	☐	☐	☐

Number	Question	Yes	No	N/A
		Or Setting		
3.8	**Critical File and Folder Permissions**			
3.8.1	Are all disk volumes on all Windows 2008 servers using the NTFS file system? *If you answered "No" to this question, and there a mission critical reason why one or more disk volumes are not configured with NTFS, use the Additional information box below to explain the mission critical reason.* Additional information: _____	☐	☐	☐
3.8.2	Have permissions on critical operating system files and folders been properly configured? **Please provide a "DumpSec" "Dump Permissions for File System" report for drive C: on all Windows 2008 servers**. Use the DumpSec "Permissions Report Options" to configure the report to "Show Owner", "Show Permissions", Show Audit Settings" and to "Show all directories and files (all dirs and files)". If you do not have "DumpSec", it can be downloaded from www.somarsoft.com. Additional information: _____	☐	☐	☐

4. Consolidated Request List

Number	Requested Item	Provided	Not Provided	Reason not provided
4.1	Electronic copy of the Local Security Policy for each Windows 2008 Server that is NOT a domain controller	☐	☐	
4.2	Electronic copy of the group policies that restrict user actions on the domain, if Group Policy is used and domain controllers run the Windows 2008 operating system	☐	☐	
4.3	"DumpSec" "Dump Services" report for all Windows 2008 servers.	☐	☐	
4.4	"DumpSec" "Dump Permissions for File System" report for drive C: on all Windows 2008 servers	☐	☐	

5. Additional Information for the Auditor on Windows 2008-based Systems